

ARQUITETURA E DESENVOLVIMENTO EM JAVA

FASE 1 | AULA 05 -

SEGURANÇA DE CONTÊINERES

SUMÁRIO

O QUE VEM POR AÍ?	3
HANDS ON.....	4
SAIBA MAIS.....	5
O QUE VOCÊ VIU NESTA AULA?.....	11
REFERÊNCIAS.....	12
PALAVRAS-CHAVE.....	13

EMSE

O QUE VEM POR AÍ?

Nesta aula, você aprenderá sobre segurança e análise de vulnerabilidades de uma imagem Docker. Também verá como não deixar a aplicação exposta, para não correr o risco de possíveis perdas.



HANDS ON

Vamos aprender a realizar uma análise de vulnerabilidades de uma imagem docker e como resolver essas vulnerabilidades utilizando imagens menores, que não possuem muitas funcionalidades pré-instaladas.

EMANIP

SAIBA MAIS

Vamos aprender a fazer análise de vulnerabilidade de imagens docker localmente. Esse tipo de ferramenta nos ajuda a identificar e corrigir vulnerabilidades, evitando que nossas aplicações tenham brechas de segurança e que fiquem expostas para que pessoas mal-intencionadas se aproveitem de tais brechas. Esse tipo de análise nos ajuda a entender melhor o uso do Docker e também a criar imagens cada vez mais seguras.

Vamos abordar a ferramenta Open Source chamada “[Trivy](#)”. O download pode ser feito baseado no Sistema Operacional utilizado. Nesta aula vamos abordar o WSL baseado em Ubuntu.

Com o comando a seguir, faremos o download e a extração do arquivo:

```
wget  
https://github.com/aquasecurity/trivy/releases/download/v0.48.0/trivy_0.48.0_Li  
nux-64bit.tar.gz && tar -xzf trivy_0.48.0_Linux-64bit.tar.gz
```

É necessário mover o arquivo extraído para o diretório binário do Linux. Com o comando a seguir, jogaremos o arquivo na pasta /usr/local/bin/:

```
sudo mv trivy /usr/local/bin/
```

Agora, com a instalação feita, garantiremos que está tudo certo verificando a versão:

```
trivy version
```

Podemos então fazer o scan da nossa imagem. Os comandos do “Trivy” são bem simples.

Abaixo, temos um dockerfile de exemplo. Caso você já tenha algum dockerfile criado, é só “buildar” e gerar a imagem para fazer o scan:

```
Dockefile-user X
node-app > Dockefile-user > ...
1 FROM node:latest
2
3 RUN adduser fiap
4
5 USER fiap
6
7 ENV DB_PASS=fiap2023
8
9 RUN export DB_PASS
10
11 RUN mkdir /tmp/user-fiap && echo "Dockerizacao" > /tmp/user-fiap/fiap.txt
12
13 CMD cat /tmp/user-fiap/fiap.txt
14
```

Figura 1 – Dockerfile Scan Trivy
Fonte: Elaborado pelo autor (2023)

No build da imagem, coloque uma tag com o comando “flag -t”. Essa tag será usada para apontarmos a imagem na qual será feita a análise:

```
→ node-app docker build -t teste-trivy -f Dockerfile-user .
Sending build context to Docker daemon 2.608MB
Step 1/7 : FROM node:latest
---> b866e35a0dc4
Step 2/7 : RUN adduser fiap
---> Using cache
---> dde799deece0
Step 3/7 : USER fiap
---> Using cache
---> 3c9fec138e5c
Step 4/7 : ENV DB_PASS=fiap2023
---> Using cache
---> 37ffdd2c29b0
Step 5/7 : RUN export DB_PASS
---> Using cache
---> 35a5c1e5a79c
Step 6/7 : RUN mkdir /tmp/user-fiap && echo "Dockerizacao" > /tmp/user-fiap/fiap.txt
---> Using cache
---> de240ab6d9b4
Step 7/7 : CMD cat /tmp/user-fiap/fiap.txt
---> Using cache
---> 373d8eb2a36a
Successfully built 373d8eb2a36a
Successfully tagged teste-trivy:latest
→ node-app
```

Figura 2 – Dockerfile Build Trivy
Fonte: Elaborado pelo autor (2023)

No exemplo, colocamos a tag “teste-trivy:latest”. Podemos executar o comando “trivy image” com o nome da imagem para iniciar a análise.

```
trivy image teste-trivy:latest
```

O resultado da análise poderá ser muito extenso dependendo de qual imagem você usar. Por padrão, a saída mostrará todos os níveis de vulnerabilidade, podendo trazer os níveis:

- **Unknown** = desconhecido (ainda não foi definida a severidade).
- **Low** = baixo.
- **Medium** = médio.
- **High** = alto.
- **Critical** = crítico.

Caso você queira ver somente a saída de um nível específico, adicione a flag “--severity” e escolha um ou mais entre os níveis citados acima. Vamos mostrar somente os níveis mais críticos: “CRITICAL” e “HIGH”.

```
trivy image --severity CRITICAL,HIGH teste-trivy:latest
```

Segurança de Contêineres

Executando o comando. A saída será mais amigável e trará somente o que definimos:

```
trivy image --severity CRITICAL,HIGH teste-trivy:latest
2023-12-10T03:17:58.360-0300 INFO Vulnerability scanning is enabled
2023-12-10T03:17:58.369-0300 INFO Secret scanning is enabled
2023-12-10T03:17:58.369-0300 INFO If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2023-12-10T03:17:58.369-0300 INFO Please see also https://aquasecurity.github.io/trivy/v0.48/docs/scanner/secret/#recommendation for faster secret detection
2023-12-10T03:18:05.369-0300 INFO Detected OS: debian
2023-12-10T03:18:05.370-0300 INFO Detecting Debian vulnerabilities...
2023-12-10T03:18:05.445-0300 INFO Number of language-specific files: 1
2023-12-10T03:18:05.445-0300 INFO Detecting node-pkg vulnerabilities...

teste-trivy:latest (debian 12.2)
Total: 60 (HIGH: 57, CRITICAL: 3)
```

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
git	CVE-2023-25652	HIGH	affected	1:2.39.2-1.1		git: by feeding specially crafted input to 'git apply --reject', a path...
	CVE-2023-29087					git: arbitrary configuration injection when renaming or deleting a section from a...
git-man	CVE-2023-25652					git: by feeding specially crafted input to 'git apply --reject', a path...
	CVE-2023-29087					git: arbitrary configuration injection when renaming or deleting a section from a...
imagemagick	CVE-2021-3610			8:6.9.11.60+dfsg-1.6		heap-based buffer overflow in ReadTIFFImage() in coders/tiff.c
imagemagick-6-common						
imagemagick-6.q16						
libaom3	CVE-2023-39616			3.6.0-1		AOMedia v3.0.0 to v3.5.0 was discovered to contain an invalid read mem...
libde265-0	CVE-2023-27183		fixed	1.0.11-1	1.0.11-1+deb12u1	Libde265 v1.0.11 was discovered to contain a heap buffer overflow via ...
	CVE-2023-43887					Libde265 v1.0.12 was discovered to contain multiple buffer overflows v ...
libharfbuzz0b	CVE-2023-25193		affected	6.0.0+dfsg-3		harfbuzz: allows attackers to trigger O(n^2) growth via consecutive marks
libldap-2.5-0	CVE-2023-2953			2.5.13+dfsg-5		null pointer dereference in ber_memalloc_x function
libmagickcore-6-arch-config	CVE-2021-3610			8:6.9.11.60+dfsg-1.6		heap-based buffer overflow in ReadTIFFImage() in coders/tiff.c

Figura 3 – Trivy Node 18 Scan
Fonte: Elaborado pelo autor (2023)

Segurança de Contêineres

Se existirem muitas vulnerabilidades, podemos analisar somente o nível “CRITICAL”, reduzindo a saída.

```
trivy image --severity CRITICAL teste-trivy:latest
2023-12-10T03:24:05.060-0300 INFO Vulnerability scanning is enabled
2023-12-10T03:24:05.060-0300 INFO Secret scanning is enabled
2023-12-10T03:24:05.060-0300 INFO If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2023-12-10T03:24:05.060-0300 INFO Please see also https://aquasecurity.github.io/trivy/v0.48/docs/scanner/secret/#recommendation for faster secret detection
2023-12-10T03:24:12.730-0300 INFO Detected OS: debian
2023-12-10T03:24:12.730-0300 INFO Detecting Debian vulnerabilities...
2023-12-10T03:24:12.808-0300 INFO Number of language-specific files: 1
2023-12-10T03:24:12.808-0300 INFO Detecting node-pkg vulnerabilities...

teste-trivy:latest (debian 12.2)
Total: 3 (CRITICAL: 3)
```

Library	Vulnerability	Severity	Status	Installed Version	Fixed Version	Title
openssh-client	CVE-2023-28531	CRITICAL	affected	1:9.2p1-2+deb12u1		openssh: smartcard keys to ssh-agent without the intended per-hop destination constraints. https://avd.aquasec.com/nvd/cve-2023-28531
zlib1g	CVE-2023-45853		will_not_fix	1:1.2.13.dfsg-1		zlib: integer overflow and resultant heap-based buffer overflow in zipOpenNewFileInZip4_6 https://avd.aquasec.com/nvd/cve-2023-45853
zlib1g-dev						

Figura 4 – Trivy Node 18 scan critical only
Fonte: Elaborado pelo autor (2023)

Um ponto legal desta ferramenta é que ela gera um link na coluna “Title” apontando para uma página que dá mais detalhes a respeito da vulnerabilidade. Basta clicar no link azul que ele redirecionará você para a página automaticamente. No exemplo, pegaremos a vulnerabilidade ligada à biblioteca **openssh-client** que a imagem base node:18 tem instalada.

aqua vulnerability database Search by Keyword or CVE-ID Get Demo

Vulnerabilities Misconfiguration Runtime Security Compliance

CVE-2023-28531
Published: Mar 17, 2023 | Modified: Jul 21, 2023

ssh-add in OpenSSH before 9.3 adds smartcard keys to ssh-agent without the intended per-hop destination constraints. The earliest affected version is 8.9.

Affected Software

Name	Vendor	Start Version	End Version
Openssh	Openbsd	8.9	*

References

- <https://www.openwall.com/lists/oss-security/2023/03/15/8>
- <https://security.netapp.com/advisory/ntap-20230413-0008/>
- <https://security.gentoo.org/glsa/202307-01>

CVSS 3.x **9.8 CRITICAL** Source: **NVD**

CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS 2.x 1

RedHat/V2 1

RedHat/V3 1

Ubuntu 1

Additional information

NVD <https://nvd.nist.gov/vuln/detail/CVE-2023-28531>

CWE <https://cwe.mitre.org/data/definitions/NVD-noinfo.html>

Figura 5 – Aqua Vulnerability Database
Fonte: Elaborado pelo autor (2023)

A informação sobre essa biblioteca diz que o componente ssh-add no OpenSSH (anterior à versão 9.3) adiciona chaves de Smartcard ao ssh-agent sem restrições, o que caracteriza vulnerabilidade. Isso significa que a imagem selecionada (nesse caso, a node:18) tem a versão do OpenSSH antes da versão 9.3, que ainda possui esse problema.

Uma abordagem que pode reduzir as vulnerabilidades é escolher imagens com bases mais enxutas, que não tenham tantos pacotes e funcionalidades, pois muitas vezes nossa aplicação não precisará deles para funcionar.

No exemplo abaixo, pegamos uma imagem do node reduzida. Percebam o quanto as vulnerabilidades diminuíram. Usamos a mesma versão do node, a versão 18, porém utilizamos a variação “alpine” que, além de ser bem menor, não possui nenhuma vulnerabilidade:

```
➤ ~ trivy image node:18-alpine
2023-12-10T04:16:57.897-0300 INFO Vulnerability scanning is enabled
2023-12-10T04:16:57.897-0300 INFO Secret scanning is enabled
2023-12-10T04:16:57.897-0300 INFO If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2023-12-10T04:16:57.897-0300 INFO Please see also https://aquasecurity.github.io/trivy/v0.48/docs/scanner/secret/#recommendation-for-faster-secret-detection
2023-12-10T04:16:57.902-0300 INFO Detected OS: alpine
2023-12-10T04:16:57.902-0300 INFO Detecting Alpine vulnerabilities...
2023-12-10T04:16:57.903-0300 INFO Number of language-specific files: 1
2023-12-10T04:16:57.903-0300 INFO Detecting node-pkg vulnerabilities...

node:18-alpine (alpine 3.18.5)

Total: 0 (UNKNOWN: 0, LOW: 0, MEDIUM: 0, HIGH: 0, CRITICAL: 0)

➤ ~ |
```

Figura 6 – Node Alpine
Fonte: Elaborado pelo autor (2023)

O QUE VOCÊ VIU NESTA AULA?

Nesta aula, você aprendeu sobre as vulnerabilidades e como analisá-las usando a ferramenta open source chamada “Trivy”. Vimos também como melhorar o funcionamento da aplicação escolhendo as imagens corretas.

EMANDA

REFERÊNCIAS

Aqua Vulnerability Database. Aqua Vulnerability Database. 2023. Disponível em: <<https://avd.aquasec.com/nvd/2023/cve-2023-28531/>>. Acesso em: 09 jan. 2024.

O que é Segurança de Contêneires Docker?. TrendMicro. [s.d]. Disponível em: <https://www.trendmicro.com/pt_br/what-is/container-security/docker.html>. Acesso em: 09 jan. 2024.

Scanning Docker Images for Vulnerabilities. Medium. [s.d]. Disponível em: <<https://medium.com/@maheshwar.ramkrushna/scanning-docker-images-for-vulnerabilities-using-trivy-for-effective-security-analysis-fa3e2844db22>>. Acesso em: 09 jan. 2024.

TRIVY Documentation. Trivy. [s.d]. Disponível em: <<https://aquasecurity.github.io/trivy/v0.48/>>. Acesso em: 09 jan. 2024.

PALAVRAS-CHAVE

Alpine. Trivy. Vulnerabilidade.

EMEND



POSTECH